

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
March 2026	Planning	Audit Program Risk Alignment	Dee Burris	Update defined risk areas (rename one and remove one) and links
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes to audit risk levels from recent revalidation
February 2025	Control Assessment Questions	2. Compliance with Government Trade Regulations	Dee Burris	Removed
	Process and Objective and Planning	Audit Program Risk Alignment		Updated some wording and links and removed ICO/EMO
April 2023	Cybersecurity and Data Protection	DP001.S	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	4
PLANNING: Data Analysis.....	5
PLANNING: Reference Material	6
PLANNING: Fraud Template.....	7
CONTROL ASSESSMENT QUESTIONS	8
Key Control Question: 1. Policy Advocacy	8
Primary Test: Involvement with Government Officials (PA001.P).....	9
Primary Test: Lobby Regulations and Reporting (PA002.P)	10
Primary Test: Contracted Services (PA003.P)	11
Key Control Question: 2. Market Support for Government Sales Assistance	12
Primary Test: Involvement with Government Officials (MS001.P).....	13
Key Control Question: 3. Access Management and Data Protection	14
Secondary Test: Access Management and Data Protection (DP001.S)	15

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

PROCESS AND OBJECTIVE

IBM's Government and Regulatory Affairs (GRA) team provides IBM with strategic public policy insight, helping business units develop public policy, and engages in worldwide policy advocacy with governments to drive growth and innovation in the digital economy. With dedicated resources in the Americas, Europe, Africa, and Asia, they have an objective of global consistency and local relevancy in a rapidly changing world.

The GRA role encompasses working with other organizations in IBM to develop IBM's public policies (such as those related to workforce, tax, technology, and trade) and advocate them with governments to support business growth and innovation. GRA also provides market support to IBM sales and brand teams in the form of strategic, tailored public policy insight, and government relations advocacy support to help them pursue growth revenue opportunities. Finally, the Enterprise Risk Management (ERM) application should relate to involvement with government officials and advice on and compliance with regulatory requirements including regulatory changes. To apply ERM, the audit team should ensure that involvement with government officials is in compliance with IBM's policies and that activities such as lobbying are in compliance with local regulations

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

PLANNING: Audit Program Risk Alignment

Government and Regulatory Affairs

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Involvement with Government Officials	High	Policy Advocacy Market Support for Government Sales Assistance	PA001.P MS001.P
Contracted Services/Vendor Relations	Medium	Policy Advocacy	PA003.P
Lobby Regulations	Medium	Policy Advocacy	PA002.P
Access Management and Data Protection	Low	Cybersecurity and Data Protection	DP001.S

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Lobbying expenses	Compare a listing of all lobbying expenses incurred to the lobbying report submitted.	Unapproved lobbying expenses or missing lobbying expenses from the required reporting.	This could indicate that the process utilized to prepare the lobbying reporting is not complete.
External lobbying expense	Compare the costs incurred for external lobbyists to approved contracts maintained in a central repository.	Unapproved contracts with external lobbyists.	This could indicate that the approval process is not being followed.
Political contributions	Compare a listing of political contributions (as defined for lobbying disclosure LD-203 reporting purposes) to the political contributions report submitted.	Missing political contributions from the required reporting.	This could indicate that the process utilized to prepare the political contributions reporting is not complete.
Department Expenses	Validate expenses incurred are consistent with budgeted activities and are in compliance with all regulations.	Unauthorized expenses.	This could indicate that expenses were not properly authorized or violated external regulations.

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

PLANNING: Reference Material

- Government and Regulatory Affairs (GRA) home page for missions and activities <https://w3.ibm.com/w3publisher/ibmgra>
- US Government website for lobbying disclosure online: <https://lobbyingdisclosure.house.gov/>
- US Lobbying Disclosure report LD-203: <https://lda.congress.gov/lc/>
- Process on lobbyist and consultant vetting procedures may be accessed here: [IBMGRA - Resources for GRAers](#)
- IBM Business Conduct Guidelines: <https://w3.ibm.com/ibm/corporate-documents/business-conduct-guidelines>
- Corporate Policy Letter 103 Business Conduct and Ethics: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-103>
- Corporate Policy Letter 125 Political Contributions and Employee Participation in Politics: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-125>
- Corporate Instructions - Government and Regulatory Affairs:
 - GRA101 - Boycotts by foreign countries - worldwide prohibition and reporting obligation <https://w3.ibm.com/ibm/corporate-documents/gra/gra-101> (same as LEG113)
 - GRA103 - Political campaign contributions; public policy expenditures; and political campaigning on IBM Proper <https://w3.ibm.com/ibm/corporate-documents/gra/gra-103>
 - GRA104 - IBM Business Operations Under The International Traffic In Arms Regulations (ITAR) <https://w3.ibm.com/ibm/corporate-documents/gra/gra-104>
- Corporate Organization Letter 116 Delegation of Authority - Government relations on public policy issues: <https://w3.ibm.com/ibm/corporate-documents/leg/leg-116>
- Corporate Instruction PROC 167 - Supplier sourced goods and services: <https://w3.ibm.com/ibm/corporate-documents/proc/proc-167>
- Corporate Instructions - Finance: <https://w3.ibm.com/ibm/corporate-documents/fin>
 - FIN 101 - Control of Disbursements
 - FIN 154 - Foreign Corrupt Practices Act: Anti-bribery, record keeping, and internal control requirements
 - FIN/LEG - 168 Business Amenities and Gifts
- What is CTEBA guidance - Compliance with Transportation, Entertainment, and Business Amenities (CTEBA) Process for Government Owned Entities ("GOE") in any country and all Commercial Parties in Certain Countries ("CPICC"): <https://w3.ibm.com/w3publisher/cteba>
- Corporate Policy 130 – Data Privacy: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-130>
- European Union (EU) General Data Protection Regulation (GDPR) Compliance Framework: <https://w3.ibm.com/w3publisher/ibm-systems-biso/reference-and-guidance/compliance-and-regulatory/general-data-protection-regulation-gdpr>

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Unauthorized payments related to involvement with government officials, including the use of third parties to act on behalf of IBM.	1. Payment controls 2. System access controls.	• Contractor / vendor payments have authorized approvals with valid supporting documentation. • Lobbyist / consultants have undergone the appropriate vetting process prior to performing work.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Policy Advocacy

Objective:

Within the scope of policy advocacy, the Government and Regulatory Affairs (GRA) organization has the responsibility to work with internal clients to develop IBM's public policies and then advocate these policies with government officials, perform or hire contractors to perform lobbying activities, and communicate regulatory changes that govern lobbying to IBM organizations with a need to know. Following a recent restructuring, GRA continues to provide policy advocacy with a focus on Technology (e.g., AI policy, Cybersecurity), Trade, and Workforce. Its worldwide policy advocacy mission is to drive growth and innovation in the digital economy through the mutual objectives of global consistency and local relevance. These tests are to ensure effective processes and controls exist for compliance with involvement with government officials, lobby regulations, contracted services and vendor activities, and the communication of regulatory changes to appropriate parties.

Risk/Exposure:

- Unauthorized or unapproved involvement with government officials, including the use of third parties to act on behalf of IBM could result in fines, penalties, and damage IBM's reputation.
- Inaccurate reporting or registration of lobbying activities could result in fines, penalties, and damage IBM's reputation.

Lack of controls over the selection and management of third parties could result in litigation against or a financial loss to IBM.

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Policy Advocacy

Primary Test: Involvement with Government Officials (PA001.P)

Objective:

Ensure adherence to IBM corporate policies for involvement with government officials when advocating IBM's policies with governments.

Approach:

Review the GRA process used to ensure compliance with IBM's policies related to involvement with government officials or authorities, inclusive of US Federal, US state or local, and Foreign, on a periodic basis, and steps taken to ensure compliance.

Validate that any individuals, including third parties acting on behalf of IBM, that interacted with government officials were authorized and approved to do so, and were reviewed for compliance with internal requirements and external regulations. For IBMers, this would include validation of annual Business Conduct Guidelines (BCG) and Compliance with Transportation, Entertainment, and Business Amenities (CTEBA), as applicable. For consultants and speakers, the CTEBA was completed as applicable. Lobbyists were registered as authorized.

Review any cases of inappropriate interaction identified, and determine if appropriate corrective action was taken to prevent reoccurrence.

Review any requests from employees for political contributions or political activity per section 7.4 of the BCG and verify if any restrictions occurred that could impact IBM.

Confirm if any gifts or amenities were provided to employees, officials of Government Owned Entities (GOEs) or to commercial parties in certain countries as listed in FIN 168 (CPICC). For all gifts or amenities, validate that appropriate approvals were obtained through applications like the Global Event Solution tool or CTEBA.

Refer the following for compliance with regulations around involvement with government officials:

- Corporate Instruction GRA 103 covers Political Contributions, public policy expenditures, and political campaigning on IBM Property.
- Corporate Organization Letter 116 Delegation of Authority - Government relations on public policy issues.
- Corporate Instruction Finance 168 on Business Amenities and gifts.
- CTEBA process
- Key sections of Business Conduct Guidelines relating to government officials and running for political office include:
 - 6.2 Giving and Receiving Business Amenities and Gifts
 - 6.6 Visiting IBM Property – Government Officials and Candidates for Public Office
 - 7.4 Participating in Public Service and Political Activity

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Policy Advocacy

Primary Test: Lobby Regulations and Reporting (PA002.P)

Objective:

To validate that all lobbying activities worldwide have been authorized by the GRA team. The authorizations comply with the countries regulations on lobbying and were appropriately reported or registered as required.

Approach:

Review a sample of quarterly lobbying reports to verify that information is being communicated accurately and timely to the US Government and any other government where required. Verify that the rate applied to the hours spent on lobbying activities. Confirm that any visits by senior executives for political issues were included on the report. Validate the travel expenses, hotel, time, and flight operations reports match what was reported.

Review the process used by the GRA team to monitor worldwide lobbying regulations on a periodic basis, and steps taken to ensure compliance. Where necessary, review the change in regulation communication to impacted teams to ensure it provided updates to report new lobby requirements.

Review reports/ communications related to the GRA lobbyist and consultant vetting procedure to ensure compliance. The process was implemented around August 2018 with the word document included in the reference section.

Validate that all employees engaged in lobbying activities have been properly registered with the US Government or other government if required. Ensure training communications provide adequate advice on where to find regulations, communications on changes, and registration and reporting requirements.

Validate that all registered lobbyists have completed the semiannual reporting for any political contributions.

Review any requests from employees for lobbying activities per section 6.5 Lobbying of the Business Conduct Guidelines (BCG) and verify if any violations were identified.

Refer to the reference page for links to the following regarding lobbying activities and regulations. Note that other countries may have similar documents that should be checked for significant changes prior to selecting samples.

- US Government website for lobbying disclosure online
- US Lobbying Disclosure report

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Policy Advocacy

Primary Test: Contracted Services (PA003.P)

Objective:

To validate if consultants and contracted vendors were selected using current purchasing guidelines, with due diligence on selection criteria, have documented contracts that define the scope of work and include clauses to adequately protect IBM's interests, have not exceeded the country Human Resources guideline for maximum length of service, and that vendor payments were fully supported and properly approved.

Approach:

Review and analyze the transactions and dollars spent for consultants, legal fees, or other contracted services that primarily relate to policy advocacy and/or lobbying activities, including any legal firm engaged to perform due diligence and background checks on outside lobbyists and consultants per the vetting procedure. (Note if contracted service is covered under one scope area, auditor should check other key control questions for specific tests.)

Identify payments made prior to contract signing date, suppliers not listed as registered to lobby, or identify high dollar transactions as potential samples to test the following:

- Were the Procedures for Vetting GRA Lobbyists and Consultants, copy included in the reference section, followed before hiring or renewing applicable GRA contracts?
 - Within the vetting process, verify a completed questionnaire was received and evidence of due diligence searches was stored.
 - Were potentially adverse findings identified during the screening process, and if so, were these findings provided to the designated IBM contact for review?
- Did a signed contract exist?
- Did contract contain scope of work or deliverables?
- Did the contract contain proper legal clauses and fees to be paid?
- Was vendor selection supported?
- Was vendor registered as required by the local government to perform lobby activities?
- Was procurement involved in the transaction or was the transaction exempt from the requirement to involve procurement?
- Were payments to vendors supported (i.e., supplier invoice)?
- Were payments properly approved?
- If contractor is former employee were guidelines followed in contracting for these services?
- Was receipt of services verified?
- Was reimbursement for vendor travel supported by copies of receipts for travel?
- Did the contract include the appropriate anti-bribery/corruption terms?
- Were data protection requirements, included in key control question 43, met, including the European Union General Data Protection Regulation (GDPR) when applicable?

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Market Support for Government Sales Assistance

Objective:

The Government and Regulatory Affairs (GRA) organization has a worldwide Market Support team to assist IBM Sales and Brand teams pursue growth revenue opportunities by providing strategic public policy insight and government relations advocacy support. These tests are to ensure effective processes and controls exist for compliance with involvement with government officials including the Foreign Corrupt Practices Act (FCPA).

Risk/Exposure:

- Unauthorized or unapproved involvement with government officials, to act on behalf of IBM could result in fines, penalties, and damage IBM's reputation.
- Improper or perceived to be improper activities during market support activities to government clients could result in violations of FCPA.

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Market Support for Government Sales Assistance

Primary Test: Involvement with Government Officials (MS001.P)

Objective:

Ensure an effective process and controls are in place for compliance with regulations and IBM corporate policies for involvement with government officials. Market Support teams work opportunities in the public sector and have increased risk of perceived improper activities requiring oversight.

Approach:

Validate GRA's adherence to IBM requirements on involvement with government officials or authorities, inclusive of US Federal, US state or local, and Foreign, on a periodic basis, and steps taken to ensure compliance.

Select samples of sales transactions to which GRA provided Market Support to ensure the transactions were handled in a way that does not give the appearance of violating any regulations or IBM corporate instructions, specifically FIN 154 on FCPA and anti-bribery.

Validate that any individuals within GRA that interacted with government officials were authorized and approved to do so, and were reviewed for compliance with internal requirements and external regulations. For IBMers, this would include validation of annual Business Conduct Guidelines (BCG) and Compliance with Transportation, Entertainment, and Business Amenities (CTEBA), as applicable.

Review any cases of inappropriate interaction identified, and determine if appropriate corrective action was taken to prevent reoccurrence.

Review any requests from employees for political contributions or political activity per section 7.4 of the Business Conduct Guidelines (BCG) and verify if any restrictions occurred that could impact IBM.

Confirm if any gifts or amenities were provided to employees, officials of Government Owned Entities (GOEs) or to commercial parties in certain countries as listed in FIN 168 (CPICC). For all gifts or amenities, validate that appropriate approvals were obtained through applications like the Global Event Solution tool or Compliance with Transportation, Entertainment, and Business Amenities (CTEBA).

Refer the following for compliance with regulations around involvement with government officials:

- Corporate Instruction FIN 154 covers Foreign Corrupt Practices Act: Anti-bribery, record keeping, and internal control requirements.
- Corporate Organization Letter 116 Delegation of Authority - Government relations on public policy issues.
- Corporate Instruction Finance 168 on Business Amenities and gifts.
- CTEBA process.

Key sections of Business Conduct Guidelines relating to sales to government entities, interactions with government officials, and running for political office include:

- 5.2 Working with Government Entities and Government Owned Entities (GOEs)
- 6.1 Protecting Against Corruption
- 6.2 Giving and Receiving Business Amenities and Gifts
- 6.3 Avoiding Money Laundering and Funding Terrorist Activities
- 6.4 Selling in the Public Sector
- 6.6 Visiting IBM Property – Government Officials and Candidates for Public Office
- 7.4 Participating in Public Service and Political Activity

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Access Management and Data Protection

Objective:

To ensure the communications both internal to IBM and external to suppliers have the appropriate level of protection to avoid divulging unnecessary sensitive information to parties without a need to know. In addition, to gain assurance that controls are in place both within IBM and at our suppliers to ensure compliance with the European Union General Data Protection Regulation (GDPR).

Risk/Exposure:

Failure to protect Government and Regulatory Affairs data to appropriate levels could result in data breaches that could result in regulatory violations, damage to IBM's image, and expose IBM to the risk of litigation.

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Access Management and Data Protection

Secondary Test: Access Management and Data Protection (DP001.S)

Objective:

Evaluate whether Government and Regulatory Affairs (GRA) data was appropriately secured and protected both within IBM and external to suppliers.

Approach:

This will not be a separate scope area; however, in all scope areas, sample testing of communications will validate that the data was appropriately protected per IBM corporate guidelines and regulatory requirements, where applicable.

Evaluate security of communications and file transfers by checking that where applicable there was encryption, password protections, no passwords were included in the same communication with protected files, and there was a need to know for shared sensitive information.

Assess the data shared for applicability with the European Union (EU) General Data Protection Regulation (GDPR). Links are included below to reference materials.

Review contracts with suppliers and contractors for their methods on assuring data privacy. Validate whether IBM requires periodic reviews, such as Statement of Standards for Attestation Engagements (SSAE) No. 16 and if IBM monitors supplier protection of data and compliance with regulatory requirements. Assess whether GDPR could apply to any of the information being provided and how the supplier complies with the regulations (note it is not necessary for the supplier to be in the EU for this to apply).

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

GOVERNMENT AND REGULATORY AFFAIRS

AUDIT PROGRAM #50-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Access Management and Data Protection

Secondary Test: Access Management and Data Protection (DP001.S)

(Continued)

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Privacy Impact Assessment (PIA) for the processes and/or assets. Complete the testing based on the latest CA&AS required data privacy education.

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing based on the latest CA&AS required data privacy education.

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

A few links to corporate or regulatory guidance to assist in understanding the requirements for access management and data privacy are listed here:

- Data Privacy/Protection, Regulations, and Compliance <https://w3.ibm.com/w3publisher/dprc>
 - IBM Guidelines for the Protection of Employee Information
 - Guidance on PI and SPI
 - PIA
 - Global Process Owner's process requirements, documentation, and guidance
 - Process requirements at a region, country, or local level
 - Laws and regulations
- GDPR Compliance Framework <https://w3.ibm.com/w3publisher/ibm-systems-biso/reference-and-guidance/compliance-and-regulatory/general-data-protection-regulation-gdpr>
- Corporate Instruction GRA 104 covers prohibited communications of U.S. Defense articles and services <https://w3.ibm.com/ibm/corporate-documents/gra/gra-104>